Set Exercises

Introduction

We will be talking about the July 2024, KnowBe4, a cyber security company attack. The organisation accidently employed a North Korean spy posing as a software engineer. Luckily, as the blog had mentioned there was no data lost (Sjouwerman 2024).

It is important to consider the depth of the attacks and the threat vectors, which will give us a good understanding on how the attack was achieved. Following along from that, the research will explain how KnowBe4 had noticed the attack by the spy in the first place and what actions they took to try to prevent it.

Does this attack have a giant effect on organisations and is there any evidence of it being a world-wide problem or was the problem contained? Lastly, was the attack successful, were they able to stop it? These are all things that we will be looking closely at.

Having that KnowBe4 revealed the incident to the public, we can learn from what had happened and further inform organisations the importance of building a stronger protection system.

Background

Researching the attack, it was stated that the hacker was able to attack through obtaining a stolen U.S. identity and use a fake image created from AI, which allowed them to get through the hiring process. These hiring processes include background checks, verified references and multiple video interviews. Once infiltrating the organisation, he then requested a Mac to be sent to an address in Washington so that they could use a remote work setup (Bracken, 2024).

The attacker used a raspberry pi to transfer the malware and tried to change the session history files (Naraine, 2024). The date and time of the activities was revealed to have happened July 15, 2024, at 9:55 pm EST. The attacker was contacted but had explained that he was troubleshooting a router issue. SOC had reached out to get more information on the situation but was not able to contact the attacker through a phone call. They were able to obtain the device around 10:20 EST (Sjouwerman, 2024).

Reflecting on the incident, we can understand the importance of implementing rigorous vetting processes. AI-generated imagery is becoming more convincing. Through the information that I have found, an effective way to combat this would be first to encourage continuous monitoring. Another way that could resolve the issue would be making sure that the companies IT, HR, and security team to be keeping an eye on any potential infiltration attempts. This is important in the case that a person does get through the cracks and attempt to infiltrate (Alger, 2024).

Indications of compromise

The organisation would be able to identify the usual activities through their security monitoring systems. Any unauthorised downloads or attempts at implementing malware would notify as a potential threat (KnowBe4, 2025).

Phishing email are one of the biggest used ways to scam people, which means in the wrong hands, unknowing victims can be taken advantage by it. Evidence of this is seen in a press release that KnowBe4 has released, it has stated that it is Security and HR-Related emails that are catching out people. KnowBe4 stated that it is 'holding the number one spot at 41%' (KnowBe4, 2021).

The press release shows that 'Social media messages are another area of concern when it comes to phishing, and LinkedIn phishing messages' (KnowBe4, 2021). This was around the time where more people were working online because of the COVID lockdowns but the problem continues with these phishing tactics, to this day.

An example of what attackers were using were discovered by KnowBe4 after going through tens of thousands of phishing tests. They were able to obtain the top 10 subjects for a general email, in respective to phishing, which are presented below:

Top 10 General Email Subjects:

- Password Check Required Immediately
- Vacation Policy Update
- Important: Dress Code Changes
- ACH Payment Receipt
- Test of the [[company_name]] Emergency Notification System
- Scheduled Server Maintenance -- No Internet Access
- COVID-19 Remote Work Policy Update
- Scanned image from MX2310U@[[domain]]
- Security Alert
- Failed Delivery

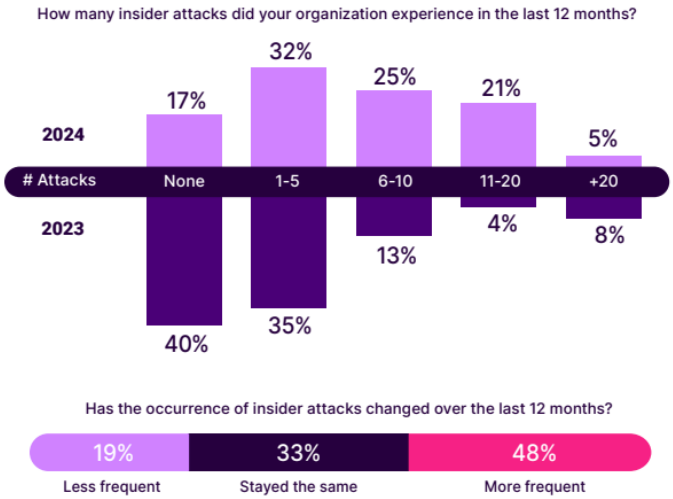
(KnowBe4, 2021).

Is there a widespread issue?

It had been stated that the scam had made North Korea hundreds of millions of dollars. Stated by the US justice department, 'allowing it to evade sanctions and continue to fund its nuclear weapons programme' (Ensor, 2024). As stated above, the implication of this could be greater than just scamming the citizens but could also endanger the country by funding North Korea with their nuclear weapons programme that could be used against us.

There is also evidence of US citizens help enable north Korean IT workers to infiltrate. In May 2024, a resident of Arizona called Christina Marie Chapman, 49-year-old women had been arrested and charged for allegedly being a part of helping North Koreans infiltrate over 300 US companies (Sergiu Gatlan, 2024).

From what I had discovered, '48% of organizations reported that insider attacks have become more frequent over the past 12 months' (GURUCUL, 2024). With this statistic, it shows how great the problem is and why it is important. To stop this kind of attack and make sure these events from happening again, companies need to improve in their measures of defence, through the hiring stages.



(GURUCUL, 2024).

Looking at the diagram above, you can see the that in 2023 there were less reported rates of insider attacks from 40%. This is a giant difference from the other side of the diagram, saying there was none to 17% in 2024, implying that there are more insider attacks than ever. This can be a terrifying factor, knowing that intensity of these attacks. Under the bar chart, you can see how frequent these attacks are happening. Knowing that there is a 48% increase in attacks should be a wakeup call for business to invest into better cybersecurity protection (GURUCUL, 2024).

KnowBe4 was incredibly lucky that they were not forced to pay any kind of random payment. From an article by The Hacker News, SecureWorks Counter Threat Unit (CTU) said "In some instances, fraudulent workers demanded ransom payments from their former employers after gaining insider access, a tactic not observed in earlier schemes" (News, T.H, 2024)

Why did the attack succeed?

Through researching the reasons why, it was a success would go down to the fact that there were not any measures to properly identify the person. As for their background, they would not of had any social media presence, which would have caused suspicion. They had stated that they will be adding more greater security measures. This would include having all employees having their fingerprints scanned (Sjouwerman, 2024).

Knowing what we know now, the attacker acted quickly to deploy the malware. Although the company had good detection systems, their actions in contacting and resolving the problem became an issue. Luckily, flagging the problem early, they were able to identify the threat.

Discussion

I feel that companies are starting to realise the problem of cybersecurity and important it is for keeping your business safe. As for who really is at threat, the smaller company who may not be able to afford appropriate security, a greater concern. They would be in increased risk of getting attack. Most companies would rely on outdated tools and may not even be protected with antivirus, firewalls, or encryption.

By not upgrading to new antivirus, you would be susceptible to a technique called 'polymorphism.' This would mean that the malware will be able to hide in the background and will be harder to detect. As time moves on, new malware appear, which is why it is important to be ahead then to be left leaving your systems at risk (Caetano, M. 2024).

Looking at GURUCUL's report, I noticed that '93% of respondents consider unified visibility and control across environments to be critically important' but when it comes to acting on this, 'only 36% have a fully integrated solution that delivers unified visibility, underscoring the need for more cohesive security strategies' (GURUCUL, 2024). As this is a small percentage to an overarching 93%, this is a concerned.

Conclusion

In conclusion, the KnowBe4 attack shows the importance of cybersecurity and why it is extremely important to investigate the background of the employees that you hire and being able to identify potential infiltration attacks. it is important for companies to keep their business safe. Although the attacker was able to get past layers of security using different ways, like AI images and stealing someone identity, they were lucky of been able to identify the problem early enough for their organisation not to be in danger.

As stated before, it is important for businesses to focus on the overarching problem that a lack of integration of cybersecurity can do. The importance can stretch out from HR and IT to security teams. It is important to get companies to incorporate stronger cybersecurity measures, being the fact that there is only 36% of respondents acting but only 93% understanding the there is a problem (GURUCUL, 2024).

References

Alger, J. (2024). *North Korean hacker tries to access KnowBe4, security leaders react*. [online] Securitymagazine.com. Available at: https://www.securitymagazine.com/articles/100899-north-korean-hacker-tries-to-access-knowbe4-security-leaders-react [Accessed 17 Feb. 2025].

Bracken, M. (2024). *Cyber firm KnowBe4 hired a fake IT worker from North Korea*. [online] CyberScoop. Available at: https://cyberscoop.com/cyber-firm-knowbe4-hired-a-fake-it-worker-from-north-korea [Accessed 17 Feb. 2025].

Caetano, M. (2024). *The Risks Of Using Outdated Antivirus Software - TechRound*. [online] TechRound. Available at: https://techround.co.uk/guides/the-risks-of-using-outdated-antivirus-software/.

Ensor, J. (2024). *How North Korean spies are infiltrating western IT departments*. [online] Thetimes.com. Available at: https://www.thetimes.com/world/us-world/article/north-korean-spy-knowbe4-tech-wzbfrlzk6.

KnowBe4 (2021). KnowBe4 Report Finds More Users Are Falling for Security and HR-Related Phishing Attacks. *Knowbe4.com*. [online] Available at: https://doi.org/105564771/1739791516176.

KnowBe4 (2025). *Detection Rules Guide*. [online] Knowledge Base. Available at: https://support.knowbe4.com/hc/en-us/articles/7159083016723-Detection-Rules-Guide [Accessed 17 Feb. 2025].

Naraine, R. (2024). *KnowBe4 Hires Fake North Korean IT Worker, Catches New Employee Planting Malware*. [online] SecurityWeek. Available at: https://www.securityweek.com/knowbe4-hires-fake-north-korean-it-worker-catches-new-employee-planting-malware [Accessed 17 Feb. 2025].

News, T.H. (2024). *North Korean IT Workers in Western Firms Now Demanding Ransom for Stolen Data*. [online] The Hacker News. Available at: https://thehackernews.com/2024/10/north-korean-it-workers-in-western.html.

Sergiu Gatlan (2024). *US woman allegedly aided North Korean IT workers infiltrate 300 firms*. [online] BleepingComputer. Available at: https://www.bleepingcomputer.com/news/security/five-arizona-ukraine-charged-for-cyber-schemes-infiltrating-over-300-companies-to-benefit-north-koreas-weapons-program [Accessed 20 Feb. 2025].

Sjouwerman, S. (2024). *How a North Korean Fake IT Worker Tried to Infiltrate Us*. [online] blog.knowbe4.com. Available at: https://blog.knowbe4.com/how-a-north-korean-fake-it-worker-tried-to-infiltrate-us.

GURUCUL (2024). *2024 Report Insider Threat*. [online] Gurucul.com. Available at:

https://go1.gurucul.com/2024-insider-threat-report?_gl=1.